

中华人民共和国通信行业标准

YD XXXX.2—XXXX

网络安全产品能力评价体系 第2部分：指
标要求

The capability evaluation system of cyber security products — Part 2: Indicators
requirements

(点击此处添加与国际标准一致性程度的标识)

(报批稿)

XXXX - XX - XX 发布

XXXX - XX - XX 实施

目 次

前 言	II
引 言	III
1 范围	4
2 规范性引用文件	4
3 术语和定义	4
4 评价对象	5
5 安全产品成熟度要求	5
5.1 网络安全硬件产品	5
5.1.1 第1级要求	5
5.1.2 第2级要求	5
5.1.3 第3级要求	6
5.1.4 第4级要求	6
5.1.5 第5级要求	6
5.2 网络安全软件产品	6
5.2.1 第1级要求	6
5.2.2 第2级要求	6
5.2.3 第3级要求	6
5.2.4 第4级要求	6
5.2.5 第5级要求	6
5.3 网络安全服务平台	6
5.3.1 第1级要求	6
5.3.2 第2级要求	6
5.3.3 第3级要求	7
5.3.4 第4级要求	7
5.3.5 第5级要求	7
6 安全产品质量要求	7
6.1 通用部分	7
6.1.1 功能性要求	7
6.1.2 性能效率要求	7
6.1.3 兼容性要求	7
6.1.4 易用性要求	7
6.1.5 可靠性要求	8
6.1.6 安全性要求	8
6.1.7 可维护性要求	8
6.2 关键部分	9
附 录 A （资料性） 基于产业视角的网络安全产品参考分类	10
参 考 文 献	11

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

YD/T XXXX《网络安全产品能力评价体系》计划包括通用方法和具体产品评价方法。其中，通用方法包括如下：

- 第1部分：概念和模型；
- 第2部分：指标要求（本文件）；
- 第3部分：评价方法；
- 第4部分：基于部署方式的安全产品测试方法；
- 第5部分：安全产品研发人员能力评价方法。

具体安全产品评价方法包括：

- 第6部分：欺骗防御（蜜罐）产品评价方法；
- 第7部分：基于零信任架构的业务安全平台评价方法；
- 第8部分：威胁检测与响应产品评价方法；
- 第9部分：攻击面管理产品评价方法；
- 第10部分：企业网络安全措施验证平台评价方法；

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、上海观安信息技术股份有限公司、北京天融信网络安全技术有限公司、腾讯云计算（北京）有限责任公司、楚天龙股份有限公司、新华三信息安全技术有限公司、北京奇虎科技有限公司、北京神州绿盟科技有限公司、郑州信大捷安信息技术股份有限公司、长扬科技（北京）股份有限公司、北京边界无限科技有限公司、高通无线通信技术（中国）有限公司、北京东方通网信科技有限公司、北京创安恒宇科技有限公司、深圳信息职业技术学院、中兴通讯股份有限公司。

本文件主要起草人：孟楠、戴方芳、董悦、刘起良、沈俊霞、吴威震、鲁豫、谢江、张静、王龔、倪平、曹海涛、邓君、柴永富、李永波、张屹、叶晓虎、叶建伟、刘为华、赵华、沈思源、王佳宁、王江胜、陈乔、崔婷婷、安琪、赵雨秋、卢忱、孙冲武、游世林、高峰、马伟、刘敏、王继刚。

引 言

网络安全产品正在广泛应用于日益发展的各种业务领域，其有效的使用与网络安全防护效果有着显著的关联，此外，市场上出现了由不同技术的组合、不同安全框架应用的安全产品。网络安全产品分类被进一步碎片化的细分，使得行业企业很难有效选择适用于自身业务的安全产品。帮助行业企业提供一套安全产品成熟度和质量评价的安全产品模型变得至关重要。

编制YD/T XXXX.XXXX《网络安全产品能力评价体系》的总体目标是推动网络安全产业高质量发展，为网络安全技术、产品、框架和方案的创新与应用注入强有力的动能。其定位是推动网络安全技术创新，并助力创新技术赛道安全产品落地和应用，此外，还可以供安全产品开发方、需求方和独立评价方单独使用。本文件拟由以下部分组成：

- 第1部分：概念和模型。提出了网络安全产品能力评价体系的概念和模型，明确了安全产品成熟度、安全产品质量和安全产品能力评价体系标准框架；
- 第2部分：指标要求。确立了网络安全产品能力评价指标要求，包括安全产品成熟度要求和质量要求两部分；
- 第3部分：评价方法。确立了网络安全产品能力评价方法；
- 第4部分：基于部署方式的安全产品测试方法。提供了针对部署方式下的网络安全产品通过第三方测试仪表测试的方法；
- 第5部分：安全产品研发人员能力评价方法。提出了面向安全产品研发人员的知识能力、技能能力等方面评价方法；
- 第6部分至第10部分：分别提出了欺骗防御（蜜罐）产品、基于零信任架构的业务安全平台、威胁检测与响应产品、攻击面管理产品、企业网络安全措施验证平台及具有相关功能的产品技术框架、测试检验和评价方法。

网络安全产品能力评价体系

第2部分 指标要求

1 范围

本文件确立了网络安全产品能力评价指标要求，包括安全产品成熟度要求和质量要求两部分。

本文件适用于指导网络安全产品的开发者进行产品的设计和研发，使用者进行产品选择和判断，也适用于第三方评价者进行产品的成熟度和质量评价。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069 信息安全技术 术语

GB/T 25000.51-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第51部分：就绪可用软件产品（RUSP）的质量要求和测试细则

YD/T XXXX.1-XXXX 网络安全产品能力评价体系 第1部分：概念和模型

3 术语和定义

GB/T 25069、GB/T 25000.51-2016、YD/T XXXX.1-XXXX界定的以及下列术语和定义适用于本文件。

3.1

功能性 functionality

在指定条件下使用时，产品或系统提供满足明确和隐含要求的功能的程度。

[来源：GB/T 25000.51-2016，5.1.5，有修改]

3.2

性能效率 performance efficiency

与用户实现目标的准确性和完备性相应的资源消耗。

[来源：GB/T 25000.51-2016，5.1.6，有修改]

3.3

兼容性 compatibility

在与其他产品共享通用的环境和资源的条件下，产品、系统或组件能够与其他产品、系统或组件交换信息，和/或执行其所需的功能的程度。

[来源：GB/T 25000.51-2016，5.1.7，有修改]

3.4

易用性 accessibility

在指定的使用环境中，产品或系统在有效性、效率和满意度特性方面为了指定目标可为指定用户使用的程度。

[来源：GB/T 25000.51-2016，5.1.8，有修改]

3.5

可靠性 dependability

系统、产品或组件在指定条件下、指定时间内执行指定功能的程度。

[来源：GB/T 25000.51-2016，5.1.9，有修改]

3.6

安全性 information security

为数据处理系统建立和采用的技术、管理上的安全保护，为的是保护组件、产品、系统或平台不因偶然和恶意的原因而遭到破坏、更改和泄露。

[来源：GB/T 25000.51-2016，5.1.10，有修改]

3.7

可维护性 maintainability

产品或系统能够被预期的维护人员修改的有效性和效率的程度。

[来源：GB/T 25000.51-2016，5.1.11，有修改]

3.8

用户文档集 user documentation

随同安全产品提供的协助用户使用该产品的信息。

4 评价对象

本文件中涉及的评价对象为就绪可用网络安全产品，即无论是否付费，任何用户可以不经历开发活动就能获得的具有安全能力的接口、组件、模块、系统或平台。同样也包括数字系统的安全功能模块。

本文件中涉及到的网络安全产品形态包括网络安全硬件产品、网络安全软件产品和网络安全服务平台。

本文件涉及到的网络安全产品功能可参考附录A。

5 安全产品成熟度要求

5.1 网络安全硬件产品

5.1.1 第1级要求

本项要求包括：

- a) 应明确产品有关的基本科学技术原理；
- b) 应基于科学技术原理提出实际应用设想，形成技术方案；
- c) 关键能力应在实验室条件下通过试验或仿真完成了原理性验证。

5.1.2 第2级要求

本项要求包括：

- a) 应形成产品初样（模块级），在模拟环境中进行了试验或验证；
- b) 应形成产品正样（系统级），在仿真环境中进行了试验或验证。

5.1.3 第3级要求

本项要求包括：

- a) 应形成整机安全产品工程样机，通过关键零部件、状态和使用情况的试验验证；
- b) 整机安全产品工程样机，可在真实使用环境下通过对产品工作原理的试验验证。

5.1.4 第4级要求

本项要求包括：

- a) 实际安全产品设计定型，应通过功能、性能等关键能力测试；
- b) 整机安全产品，通过典型使用环境的示范验证可进行产品小批量生产。

5.1.5 第5级要求

产品应可批量生产，功能、性能效率等能力在实际任务中得到充分验证。

5.2 网络安全软件产品

5.2.1 第1级要求

本项要求包括：

- a) 确定最终推荐的系统方案；
- b) 确定产品关键技术原理。

5.2.2 第2级要求

本项要求包括：

- a) 应确定安全软件产品的研发模式，完成原型系统研发，开展验证分析；
- b) 应完成测试版本软件研发，进行功能、性能、安全性等测试；
- c) 应完成正式版本软件研发，满足需求，达到设计目标。

5.2.3 第3级要求

应在实际环境中部署，并交付用户适用并得到确认。

5.2.4 第4级要求

应在实际生产中示范应用，各项指标满足生产要求和用户认可。

5.2.5 第5级要求

应完成推广和规模化应用。

5.3 网络安全服务平台

5.3.1 第1级要求

本项要求包括：

- a) 应提出平台建设的基本架构，完成初步调查分析或形成报告；
- b) 应开展了平台关键技术等研究，论证了可行性；
- c) 确定最终推荐的系统方案。

5.3.2 第2级要求

本项要求包括：

- a) 应对平台关键技术进行了验证；
- b) 应初步进行安全平台所需场地、设备等能力建设；
- c) 应基本完成安全平台按需技术集成等能力建设，建立服务模式。

5.3.3 第3级要求

应完成对平台的实际试用及测试，验证关键技术、服务模式等。

5.3.4 第4级要求

建设应按要求全部完成，并得到典型用户认可。

5.3.5 第5级要求

应已正式对外提供服务，关键技术、服务模式、运营机制等在实际服务中获得推广应用。

6 安全产品质量要求

6.1 通用部分

6.1.1 功能性要求

本项要求包括：

- a) 安装或部署好之后，安全产品的功能是否能执行应是可识别的；

注：对功能良好的验证可通过如下方式进行：利用所提供的测试用例，或按相应的消息自测试，或由用户进行的其他测试。

- b) 在给定的限制范围内，使用相应的环境措施、器材和数据，用户文档集中所陈述的所有功能应是可执行的；
- c) 安全产品应符合产品说明所引用的任何需求文档中的全部要求；
- d) 安全产品不应与产品说明和用户文档集矛盾；
- e) 由遵循用户文档集的最终用户对安全产品运行进行的控制与产品的行为应是一致的。

6.1.2 性能效率要求

安全产品应符合产品说明中有关性能效率的陈述。

6.1.3 兼容性要求

本项要求包括：

- a) 用户进行安装操作时，产品应提供一种方式来控制已安装组件的兼容性；
- b) 安全产品应按照用户文档集和产品说明中所定义的兼容性特征来执行；
- c) 应在用户文档集中明确说明配置安全产品环境和参数的方法以执行已定义的兼容性；
- d) 在用户文档集中应明确指明兼容性、功能、数据或流的类型；
- e) 若安全产品在安装时对组件有共存性的约束条件，应在用户进行安装前应予以明示。

6.1.4 易用性要求

本项要求包括：

- a) 用户从产品说明或通过产品界面，应知道当前产品状态及如何使用；

- b) 有关安全产品执行的各种问题、消息和结果都应是易理解的；

注：借助以下的手段可以达到易理解性：

- 恰当地选择术语；
- 图形表示；
- 提供背景信息；
- 由帮助功能解释；
- 提供易理解的文字或图形输出；
- 提供清晰的音频输出；
- 提供清晰的视频输出。

- c) 每个安全产品的出错消息应指明具体问题，方便用户排查解决；

- d) 出自安全产品的消息应设计成使最终用户易于理解的形式；

注：这些消息可能是：

- 确认；
- 产品发出的询问；
- 信息；
- 警告；
- 出错消息。

- e) 屏幕输入格式、报表和其他输出对用户来说应是清晰且易理解的；

- f) 对具有严重后果的功能执行应是可撤销的，或者产品应给出这种后果的明显警告，并且在这种命令执行前要求确认；

- g) 借助用户接口、帮助功能或用户文档集提供的手段，用户应能够学习如何使用某一功能；

- h) 当执行某一功能时，若响应时间超出通常预期限度，应告知用户；

- i) 每一元素（数据媒体、文件等）均应带有产品标识，如果有两种以上的元素，则应附上标识号或标识文字；

- j) 安全产品的用户界面应简单，并便于用户使用。

6.1.5 可靠性要求

本项要求包括：

- a) 应按照用户文档集中定义的可靠性特征来执行；
- b) 与差错处置相关的功能应与产品说明和用户文档集中的陈述一致；
- c) 在用户文档集中陈述的限制范围内使用时，安全产品不能丢失数据；
- d) 应能识别违反指定条件的输入，并且不应作为许可的输入加以处理；
- e) 应具有从错误中恢复的能力。

6.1.6 安全性要求

本项要求包括：

- a) 应按照用户文档集中定义的安全性特征来执行；
- b) 应能防止对程序和数据的未授权访问；
- c) 应能按照产品信息安全需求，对用户或进程的访问权限进行管理；
- d) 应能识别出对产品运行产生损害的事件（如：破坏结构数据库或文件完整性），且能阻止该事件，并通报给授权用户；
- e) 应能对数据进行保护，只允许授权用户访问。

6.1.7 可维护性要求

本项要求包括：

- a) 应按照用户文档集中定义的可维护性特征来执行；
- b) 应能识别出每一个基本组件的发布号，包括安装的版本，以及对产品特征产生的影响；

注：基本组件可能是子程序、接口、数据显示屏幕、数据库等。

- c) 提供良好的诊断能力，包括诊断程序、修改规程和维修经验数据、电子手册等。

6.2 关键部分

安全产品的关键部分能力在具体产品的评价方法标准中通用部分能力中体现。

注：网络安全产品能力评价体系系列标准从第5部分开始提供了对具体安全产品的评价方法。

附录 A

(资料性)

基于产业视角的网络安全产品参考分类

表A.1 网络安全产品分类

一级分类	二级分类
应用场景	云安全产品
	物联网安全产品
	车联网安全产品
	卫星互联网安全产品
	工业互联网安全产品
	5G/6G安全产品
	人工智能安全产品
	区块链安全产品
	城市运营安全产品
通用环境	网络与通信安全产品
	计算环境安全产品
	业务与应用安全产品
	数据安全产品
	身份与访问安全产品
	隐私计算产品
	密码技术产品
	软件供应链安全产品
	物理环境安全产品
	安全审计与合规产品
	安全运营与服务产品
	开发安全产品
专项防护	DDoS防护产品
	APT攻击检测与防御产品
	网络勒索分析与防御产品

参 考 文 献

- [1] GB/T 22900-2009 科学技术研究项目评价通则
 - [2] GB/T 25000.51-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第51部分：就绪可用软件产品（RUSP）的质量要求和测试细则
 - [3] GB/T 25000.40-2018 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第40部分：评价过程
 - [4] GB/T 25000.10-2016 系统与软件工程 系统与软件质量要求和评价（SQuaRE）第10部分：系统与软件质量模型
 - [5] GJB 7688-2012 《装备技术成熟度等级划分及定义》
 - [6] NASA: Technology Readiness Level
-